PENETRATION TESTING · FALL 2026

Assignment 2
Vulnerability Scan & Analysis Report

Client engagement: Acme Corp · Project Phase 2b (Vulnerability Scanning)

Course	Penetration Testing — Focus College, Fall 2026
Instructor	Arpan Bhavsar · abhavsar@focuscollege.ca
Weight	**6%** of the final course grade
Issued	Friday, October 23, 2026 (Week 4)
Due	**Friday, October 30, 2026, before midnight Pacific Time** on the LMS
Type	Individual · hands-on lab + written client report
Exam alignment	CompTIA PenTest+ PT0-002 Domain 2.0 (2.4–2.5) · PT0-003 Domain 3.0 note inside

> **Read this first.** You may only scan authorized targets: your Host-only Metasploitable 2 / DVWA lab, the course `acme_vuln_lab.py` on 127.0.0.1, and light practice on `scanme.nmap.org` only if the RoE sheet permits. Every other system is off-limits. Scanning anything else is academic misconduct and may be illegal.

Acme Corp and all Acme names are fictional teaching data (RFC 2606 / RFC 5737). Version 1.0 · October 2026.

1 Overview and learning outcomes

> **Real-example standard (new for this issue):** every Critical or High finding must cite a real CVE ID, state the score source (NVD Primary, CISA-ADP, or tester-assessed), record KEV membership and EPSS on the day you write, and include one sentence linking the finding to a documented incident (Equifax/Struts CVE-2017-5638, Heartbleed CVE-2014-0160, Log4Shell CVE-2021-44228, WannaCry/EternalBlue CVE-2017-0144, or MOVEit CVE-2023-34362 are the class exemplars). Metasploitable findings (vsftpd CVE-2011-2523, Samba CVE-2007-2447, PHP-CGI CVE-2012-1823) stay valid lab targets when framed with those real CVE records.

In Week 4 you learned to configure and run vulnerability scans with free tools (Greenbone Community Edition / OpenVAS, Nmap NSE `vuln and safe`, Nikto, searchsploit), to score findings with CVSS v3.1, and to validate false positives before reporting. This assignment is Project Phase 2b: produce a short Vulnerability Scan & Analysis Report for Acme Corp that managers can act on.

Your Assignment 1 inventory is the preferred input. Re-scanning inside Change Order CO-A2 is allowed.

Outcomes assessed: syllabus LO10, LO13, LO15, LO16 (vulnerability scanning, configuring scans, reviewing/validating reports, common vulnerability categories). Certification: PT0-002 2.4–2.5; PT0-003 Domain 3.0 Vulnerability Discovery and Analysis (~17%).

2 Scenario

Acme Corp (Surrey BC fictional retailer) continues the partially known engagement. Phase 2a produced a service inventory for acme-legacy (Metasploitable 2 stand-in) and related lab hosts. Phase 2b asks: which services have known weaknesses, how severe are they, which alerts are false positives, and what should Jordan Lee fix first?

Not in scope for A2: exploitation / Metasploit fire (Week 5), web app deep dive (Week 7), cloud (Week 9).

3 Scope and RoE (Change Order CO-A2)

Item	Phase 2b rule
Window	Class lab Fri Oct 23 evening PT, plus Sat Oct 24 – Fri Oct 30 daily within the hours printed on the RoE sheet inside the assets zip (Pacific Time). No active scanning after the window ends; writing may continue until the LMS deadline.
Targets	Host-only lab VMs; `127.0.0.1` mini lab; optional light scanme.nmap.org per sheet. Never documentation ranges live, never college/home/work/classmate hosts.
Allowed	Greenbone CE Full and fast (unauthenticated); `nmap -sV --script "vuln and safe and not http-slowloris-check"` after `scope_guard.py --nse` ALLOW; Nikto; searchsploit lookups; `cvss31.py, prioritize.py`; curl/manual verification.
Forbidden	NSE categories exploit / intrusive / dos / brute; Metasploit exploitation; credentialed scans without a further change order; submitting sample-output as your own evidence.

> Run `python3 scope_guard.py --nse "…"` before every NSE vuln expression. Paste the transcript into evidence.

4 Tasks (summary)

1. **Workspace** — folders under `~/acme-a2/evidence/`; unzip assets; record tool versions.
2. **Scope gate** — targets file + `scope_guard.py` (IP) and `--nse` (expression).
3. **Configure & run scans** — at least one of Greenbone CE **or** NSE safe-vuln on ≥1 in-scope host, **and** Nikto against an HTTP service on an in-scope host. Save raw outputs (`-oA`, Nikto file, Greenbone export).
4. **searchsploit** — look up at least two Keep findings; record paths; do not execute exploits.
5. **Validate** — document ≥1 false positive with a second-method disproof (the FrontPage mini-lab case is acceptable if you used the mini lab).
6. **Score** — CVSS v3.1 base vector + score for every Keep finding; show workings (script transcript and/or FIRST calculator screenshot).
7. **Prioritize** — order findings using CVSS plus at least one of EPSS / CISA KEV / asset / reachability; explain #1 and last.
8. **Report** — write the PDF structure below; ethics reflection 150–250 words; AI use statement.

5 Deliverables

Upload **two** files:

1. `A2_LastnameFirstname_Report.pdf`
2. `A2_LastnameFirstname_Evidence.zip` containing evidence/ (scope transcripts, scans, analysis, cvss workings, FP proof)

Report structure (suggested): Cover · 1 Executive summary · 2 Scope/RoE · 3 Methodology & tools · 4 Scan configuration · 5 Findings table (≥5 Keep) · 6 False positives · 7 Prioritization rationale · 8 Recommendations · 9 Ethics reflection · 10 AI use statement · Appendix command list.

Length guide: about 6–12 pages for sections 1–10 (cover/appendix extra).

6 Rubric (100 pts → 6%)

Criterion	Pts	Excellent
Scope / NSE policy / RoE adherence	15	Guard transcripts; only allowed expressions; clear exclusions
Scan execution & evidence quality	25	Raw -oA / Nikto / Greenbone exports; timestamps in window; no sample-output fakes
Validation & false positives	15	≥1 FP disproved with second method; confidence labels honest
CVSS scoring	15	Vector + score for each Keep; workings present; calculator/script consistent
Prioritization & business writing	15	Ordered list with KEV/EPSS/asset/reachability; CIO-readable summary
Ethics reflection (150–250 words)	10	Specific Acme refusals, not generic fluff
Evidence package / naming	5	Checklist complete; clear filenames

Automatic zero: scanning out-of-scope systems; submitting another student's scans or course sample-output as yours; empty/late without prior written approval.

7 Academic integrity & AI

Same rules as Assignment 1 and the syllabus: your scans and evidence must be yours; generative AI may help you learn or polish wording if labelled and cited in APA format; AI is not allowed to invent evidence. Include an AI use statement even if you used none.

8 References

- FIRST CVSS v3.1 — https://www.first.org/cvss/v3.1/specification-document
- NVD — https://nvd.nist.gov/vuln
- CISA KEV — https://www.cisa.gov/known-exploited-vulnerabilities-catalog
- Greenbone CE Kali docs — https://greenbone.github.io/docs/latest/22.4/kali/
- Nmap NSEDoc — https://nmap.org/nsedoc/
- Nikto — https://github.com/sullo/nikto
- CompTIA PenTest+ objectives PT0-002 / PT0-003 (PDFs on CompTIA site)